

Wireshark를 활용한 패킷 스니핑 및 방어 전략

1. 문제 상황

사내 네트워크에서 공격자가 동일한 네트워크 대역에 접속한 경우, 사용자의 웹 로그인 정보를 패킷 스니핑(Packet Sniffing)을 통해 탈취할 수 있다. 이번 실습에서는 Wireshark를 이용하여 HTTP 로그인 패킷을 캡처하고 로그인 정보(ID, Password)가 평문으로 노출되는지 확인하였다. 또한 HTTPS 환경과 비교하여 데이터 보호 방법을 확인하였다.

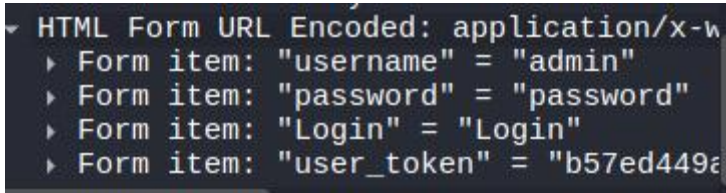
2. 실습 환경

구분	내용
운영체제	Kali Linux
패킷 분석 도구	Wireshark
웹 애플리케이션	DVWA (Damn Vulnerable Web Application)
비교 사이트	HTTPS 테스트 사이트 (demo.testfire.net)
브라우저	Firefox

3. 실습 과정

3.1 HTTP 로그인 패킷 캡처

1. Wireshark를 실행하였다.
2. 네트워크 인터페이스를 선택하여 패킷 캡처를 시작하였다.
3. Firefox에서 DVWA 로그인 페이지에 접속하였다.
4. 계정 정보를 입력하여 로그인을 수행하였다.



```
HTML Form URL Encoded: application/x-www-form-urlencoded
  Form item: "username" = "admin"
  Form item: "password" = "password"
  Form item: "Login" = "Login"
  Form item: "user_token" = "b57ed449e"
```

Username : admin
Password : password

1. Wireshark에서 다음 필터를 적용하였다.

http.request

1. POST 요청 패킷을 선택하여 Hypertext Form Data를 확인하였다.

3.2 HTTP 로그인 정보 확인

HTTP POST 패킷 내부에서 다음과 같은 로그인 정보가 평문으로 전송되는 것을 확인하였다.

username=admin

password=password

로그인 정보가 암호화되지 않은 상태로 네트워크를 통해 전송되는 것을 확인하였다.

3.3 HTTPS 비교

HTTPS 사이트에 접속하여 동일하게 로그인을 수행하였다.
Wireshark에서 다음 필터를 적용하였다.

tls

또는

tcp.port == 443

패킷을 확인한 결과,

Encrypted Application Data

만 확인되었으며

사용자의

- ID
- Password

정보는 확인할 수 없었다.

4. 실습 결과

HTTP

- 로그인 정보가 평문으로 전송됨
- Wireshark를 통해 ID와 Password를 쉽게 확인 가능

HTTPS

- TLS 암호화 적용
 - 로그인 정보가 암호화되어 평문 확인 불가
 - Encrypted Application Data만 확인됨
-

5. 방어 전략

패킷 스니핑 공격으로부터 사용자 정보를 보호하기 위해 다음과 같은 방어 방법을 적용할 수 있다.

- HTTPS(TLS) 사용
 - HTTP 사용 금지
 - 웹 서버에 SSL 인증서 적용
 - HSTS(HTTP Strict Transport Security) 적용
 - VPN 사용
 - 공용 네트워크에서 중요 서비스 접속 제한
 - 중요 서비스는 HTTPS를 강제 적용
-

6. 결론

이번 실습을 통해 HTTP 프로토콜은 로그인 정보가 암호화되지 않은 상태로 전송되므로 Wireshark를 이용한 패킷 스니핑으로 사용자 계정을 쉽게 확인할 수 있음을 확인하였다. 반면 HTTPS는 TLS 암호화를 사용하기 때문에 로그인 정보가 암호화되어 평문으로 확인되지 않았다.

따라서 실제 서비스에서는 사용자 개인정보와 로그인 정보를 보호하기 위해 반드시 HTTPS를 사용해야 하며, HTTP 대신 암호화된 통신을 적용하는 것이 중요하다.